

GENERAL DATA PROTECTION REGULATION (GDPR)
Regulation (EU) 2016/679 - Sample Extract for Testing

=====

CHAPTER I - GENERAL PROVISIONS

=====

Article 1 - Subject-matter and objectives

1. This Regulation lays down rules relating to the protection of natural persons with regard to the processing of personal data and rules relating to the free movement of personal data.
2. This Regulation protects fundamental rights and freedoms of natural persons and in particular their right to the protection of personal data.

Article 2 - Material scope

1. This Regulation applies to the processing of personal data wholly or partly by automated means and to the processing other than by automated means of personal data which form part of a filing system or are intended to form part of a filing system.

=====

CHAPTER II - PRINCIPLES

=====

Article 5 - Principles relating to processing of personal data

Personal data shall be:

- (a) processed lawfully, fairly and in a transparent manner in relation to the data subject ('lawfulness, fairness and transparency');
- (b) collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes ('purpose limitation');
- (c) adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation');
- (d) accurate and, where necessary, kept up to date ('accuracy');
- (e) kept in a form which permits identification of data subjects for no longer than is necessary ('storage limitation');
- (f) processed in a manner that ensures appropriate security of the personal data ('integrity and confidentiality').

Article 6 - Lawfulness of processing

1. Processing shall be lawful only if and to the extent that at least one of the following applies:

- (a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes;
- (b) processing is necessary for the performance of a contract to which the data subject is party;
- (c) processing is necessary for compliance with a legal obligation to which the controller is subject;
- (d) processing is necessary in order to protect the vital interests of the data subject or of another natural person;
- (e) processing is necessary for the performance of a task carried out in the public interest;
- (f) processing is necessary for the purposes of the legitimate interests pursued by the controller.

=====

CHAPTER III - RIGHTS OF THE DATA SUBJECT

=====

Article 12 - Transparent information, communication and modalities

1. The controller shall take appropriate measures to provide any information referred to in Articles 13 and 14 and any communication under Articles 15 to 22 and 34 relating to processing to the data subject in a concise, transparent, intelligible and easily accessible form, using clear and plain language.

Article 13 - Information to be provided where personal data are collected from the data subject

1. Where personal data relating to a data subject are collected from the data subject, the controller shall, at the time when personal data are obtained, provide the data subject with all of the following information:

- (a) the identity and the contact details of the controller;
- (b) the purposes of the processing for which the personal data are intended as well as the legal basis for the processing;
- (c) the period for which the personal data will be stored;
- (d) the existence of the right to request from the controller access to and rectification or erasure of personal data.

Article 15 - Right of access by the data subject

1. The data subject shall have the right to obtain from the controller confirmation as to whether or not personal data concerning him or her are being processed, and, where that is the case, access to the personal data.

Article 16 - Right to rectification

The data subject shall have the right to obtain from the controller without undue delay the rectification of inaccurate personal data concerning him or her.

Article 17 - Right to erasure ('right to be forgotten')

1. The data subject shall have the right to obtain from the controller the erasure of personal data concerning him or her without undue delay and the controller shall have the obligation to erase personal data without undue delay where one of the following grounds applies:

- (a) the personal data are no longer necessary in relation to the purposes for which they were collected or otherwise processed;
- (b) the data subject withdraws consent on which the processing is based;
- (c) the data subject objects to the processing and there are no overriding legitimate grounds for the processing;
- (d) the personal data have been unlawfully processed;
- (e) the personal data have to be erased for compliance with a legal obligation.

2. Where the controller has made the personal data public and is obliged to erase the personal data, the controller shall take reasonable steps to inform controllers which are processing the personal data that the data subject has requested the erasure.

Article 18 - Right to restriction of processing

1. The data subject shall have the right to obtain from the controller restriction of processing where one of the following applies:

- (a) the accuracy of the personal data is contested by the data subject;
- (b) the processing is unlawful and the data subject opposes the erasure of the personal data;

(c) the data subject has objected to processing pending the verification whether the legitimate grounds of the controller override those of the data subject.

Article 20 - Right to data portability

1. The data subject shall have the right to receive the personal data concerning him or her in a structured, commonly used and machine-readable format and have the right to transmit those data to another controller without hindrance.
2. The right referred to in paragraph 1 shall apply where the processing is based on consent or on a contract and the processing is carried out by automated means.

=====

CHAPTER IV - CONTROLLER AND PROCESSOR

=====

Article 24 - Responsibility of the controller

1. Taking into account the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller shall implement appropriate technical and organisational measures to ensure and to be able to demonstrate that processing is performed in accordance with this Regulation.

Article 25 - Data protection by design and by default

1. The controller shall implement appropriate technical and organisational measures for ensuring that, by default, only personal data which are necessary for each specific purpose of the processing are processed.

Article 28 - Processor

1. Where processing is to be carried out on behalf of a controller, the controller shall use only processors providing sufficient guarantees to implement appropriate technical and organisational measures.
2. Processing by a processor shall be governed by a contract or other legal act that is binding on the processor with regard to the controller.

Article 30 - Records of processing activities

1. Each controller shall maintain a record of processing activities under its responsibility containing:
 - (a) the name and contact details of the controller;
 - (b) the purposes of the processing;
 - (c) a description of the categories of data subjects and personal data;
 - (d) the categories of recipients to whom the personal data have been or will be disclosed;
 - (e) where applicable, transfers of personal data to a third country;
 - (f) the envisaged time limits for erasure of the different categories of data;
 - (g) a general description of the technical and organisational security measures.

Article 32 - Security of processing

1. The controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including:
 - (a) the pseudonymisation and encryption of personal data;
 - (b) the ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems;
 - (c) the ability to restore the availability and access to personal data in a timely manner;

(d) a process for regularly testing, assessing and evaluating the effectiveness of technical and organisational measures.

Article 33 - Notification of a personal data breach to the supervisory authority

1. In the case of a personal data breach, the controller shall without undue delay and, where feasible, not later than 72 hours after having become aware of it, notify the personal data breach to the supervisory authority.

Article 34 - Communication of a personal data breach to the data subject

1. When the personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the controller shall communicate the personal data breach to the data subject without undue delay.

=====

CHAPTER V - TRANSFERS OF PERSONAL DATA

=====

Article 44 - General principle for transfers

Any transfer of personal data shall take place only if the controller and processor comply with the conditions laid down in this Chapter.

Article 45 - Transfers on the basis of an adequacy decision

1. A transfer of personal data to a third country may take place where the Commission has decided that the third country ensures an adequate level of protection.

=====

CHAPTER VI - INDEPENDENT SUPERVISORY AUTHORITIES

=====

Article 51 - Supervisory authority

1. Each Member State shall provide for one or more independent public authorities to be responsible for monitoring the application of this Regulation.

=====

CHAPTER VIII - REMEDIES, LIABILITY AND PENALTIES

=====

Article 82 - Right to compensation and liability

1. Any person who has suffered material or non-material damage as a result of an infringement of this Regulation shall have the right to receive compensation from the controller or processor for the damage suffered.

Article 83 - General conditions for imposing administrative fines

1. Each supervisory authority shall ensure that the imposition of administrative fines shall in each individual case be effective, proportionate and dissuasive.

4. Infringements of the following provisions shall be subject to administrative fines up to 10,000,000 EUR, or in the case of an undertaking, up to 2% of the total worldwide annual turnover.

5. Infringements of the following provisions shall be subject to administrative fines up to 20,000,000 EUR, or in the case of an undertaking, up to 4% of the total worldwide annual turnover:

- (a) the basic principles for processing, including conditions for consent;
- (b) the data subjects' rights;
- (c) the transfers of personal data to a recipient in a third country.

=====
END OF SAMPLE EXTRACT
=====